

Policy Owner	Effective Date	Version	Next Review Date
IT Director / HIPAA Security Officer	June 11, 2026	1.0	June 11, 2027

PURPOSE:

This policy exists to ensure that confidentiality, integrity, and availability of systems and the data within those systems is protected in accordance with HIPAA Privacy and Security Rules for the minimization of risk to the organization through responsible control of access for employees to systems and technologies.

SCOPE:

This policy applies to all employees across all three primary departments, as well as contractors, third-party vendors, and other individuals who may interact with the organization's data or systems regardless of location or employment type.

ROLES & RESPONSIBILITIES:

1. IT Director / HIPAA Security Officer - The owner of this policy and conductor of annual policy review. They will be the final approver of what systems and resources an employee can access and what they cannot
2. IT Team - Delegators of access control to systems for employees, they set up what employees can and cannot access with the IT Director being the ultimate approver.
3. Department Managers - Ensuring compliance from their staff
4. Employees - All employees under the organization are responsible for using only their assigned accounts, ensuring compliance with requirements of authentication and ensuring any suspected unauthorized access is reported to the IT team immediately.

POLICY STATEMENTS:

- 1.1 All access must be granted through a formal request process with access being assigned based on job role with the principle of least privilege applying
- 1.2 All access requests must be approved by the IT director before provisioning

- 1.3 New employees receive access on or after their start date, never before.
- 1.4 Within 24 hours of voluntary departure access must be revoked and it must be revoked same-day for involuntary termination.
- 1.5 Offboarding checklist must be completed and signed off by IT
- 1.6 All access to systems require a unique individual account, shared accounts are prohibited
- 1.7 SMS-based MFA is prohibited due to SIM swap vulnerability, MFA via authenticator app will be used instead for all EHR access and remote access.
- 1.8 Passwords must meet minimum complexity requirements per NIST SP 800-63B
- 1.9 Privileged access is limited to IT department personnel only delegated by the IT director
- 1.10 All activity done by privileged accounts are logged and reviewed
- 1.11 Administrator accounts must be separate from standard user accounts
- 1.12 Any access that is no longer needed must be immediately revoked upon review and all user access must be reviewed quarterly by IT and department managers.

COMPLIANCE & ENFORCEMENT:

Failure to comply with the Access Control Policy will lead to termination of employment as well as referral to the appropriate legal authorities depending on severity. Violations involving protected health information (PHI) may constitute a breach under HIPAA which will be reported to the appropriate regulatory authorities which include the U.S. Department of Health and Human Services (HHS) Office for Civil Rights.

EXCEPTIONS:

Exceptions to this policy must be put into a written request form and sent to the IT team and approved by the IT department director.

REVIEW CYCLE:

This policy will be reviewed annually or after any significant security incident.

VERSION HISTORY TABLE:

Version	Date	Author	Description of Changes
1.0	6/11/2026	Bryan Alcivar	Initial Policy Creation